

01. システムアーキテクチャ・非機能要件設計書

Version 1.0 (FIX) / 2026-08-17

1. システム全体構成

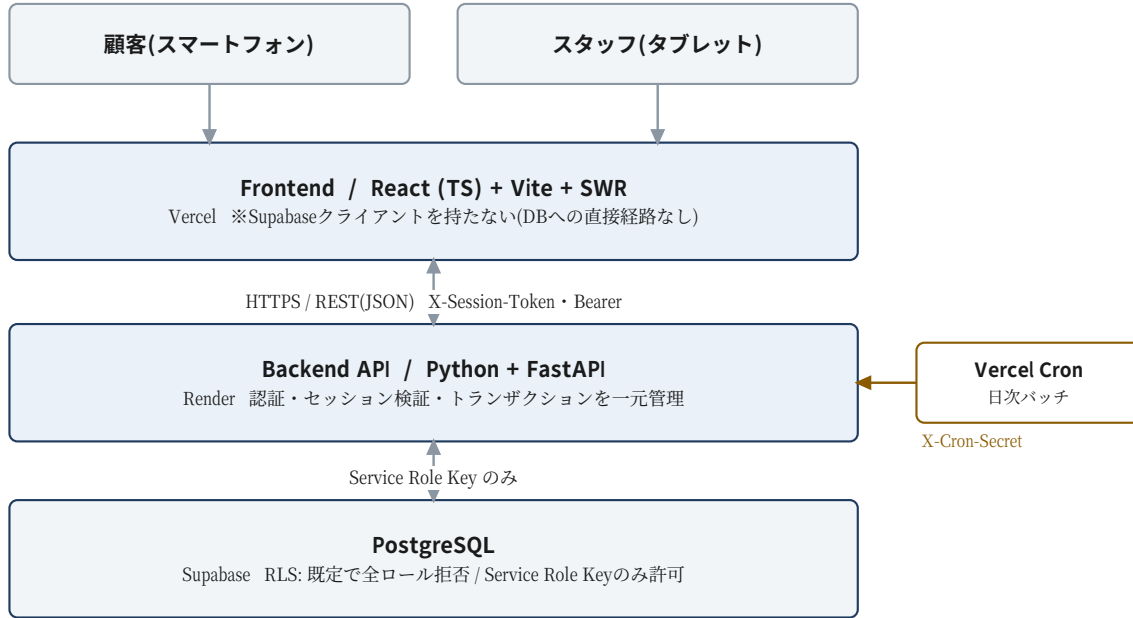


図1 システム構成図

レイヤー	技術スタック	デプロイ先	役割・特記事項
Frontend	React (TS) + Vite SWR, Zustand, Tailwind	Vercel	顧客用/店舗用UI。APIリクエストの発行のみを行う。Supabaseクライアントは保持せず、DBへの直接アクセス経路を持たない。
Backend API	Python + FastAPI Pydantic, Uvicorn	Render	ビジネスロジック、トランザクション管理、認証・セッション検証を一元的に実行する唯一の窓口。
Database	PostgreSQL	Supabase	データの永続化。RLSにより既定で全ロールを拒否し、Backend (Service Role Key)からのアクセスのみを許可する。
Batch	Vercel Cron	Vercel	日次でBackendのバッチAPIを呼び出し、閉め忘れ卓を強制クリアする。

この構成を選んだ理由

フロントエンドからDBへ直接アクセスする経路を完全に断つことで、ブラウザに露出する鍵(Anon Key)から機密データが読める可能性を構造的に排除している。認証・検証ロジックがBackendの1箇所に集約されるため、レビュー範囲が狭く保守しやすい。

2. 認証・セッション設計

2.1 2種類の認証方式

対象	方式	ヘッダー	有効期間
スタッフ	JWT(ログインで発行)	Authorization: Bearer {token}	8時間(1シフト分)
顧客	session_token(開栓で発行)	X-Session-Token: {uuid}	会計クリアまで
バッチ	共有シークレット	X-Cron-Secret: {secret}	—

2.2 スタッフ認証

- POST /api/v1/staff/login (login_id, password)
によりJWTを発行する。パスワードはbcryptでハッシュ化して保管する。
- 有効期限は8時間(1シフト分の運用を想定)。V1ではリフレッシュトークンを導入せず、期限切れ後は再ログインを求める。
- 全スタッフAPIで Authorization: Bearer {token} を検証し、未認証・期限切れアクセスを遮断する。
- POST /api/v1/staff/logout はクライアント側のトークン破棄を主目的とする。JWTはステートレスであるため、サーバー側での即時失効(ブラックリスト化)はV1のスコープ外とし、有効期限を短めに設定することで代替する。

2.3 顧客セッション(開栓方式)

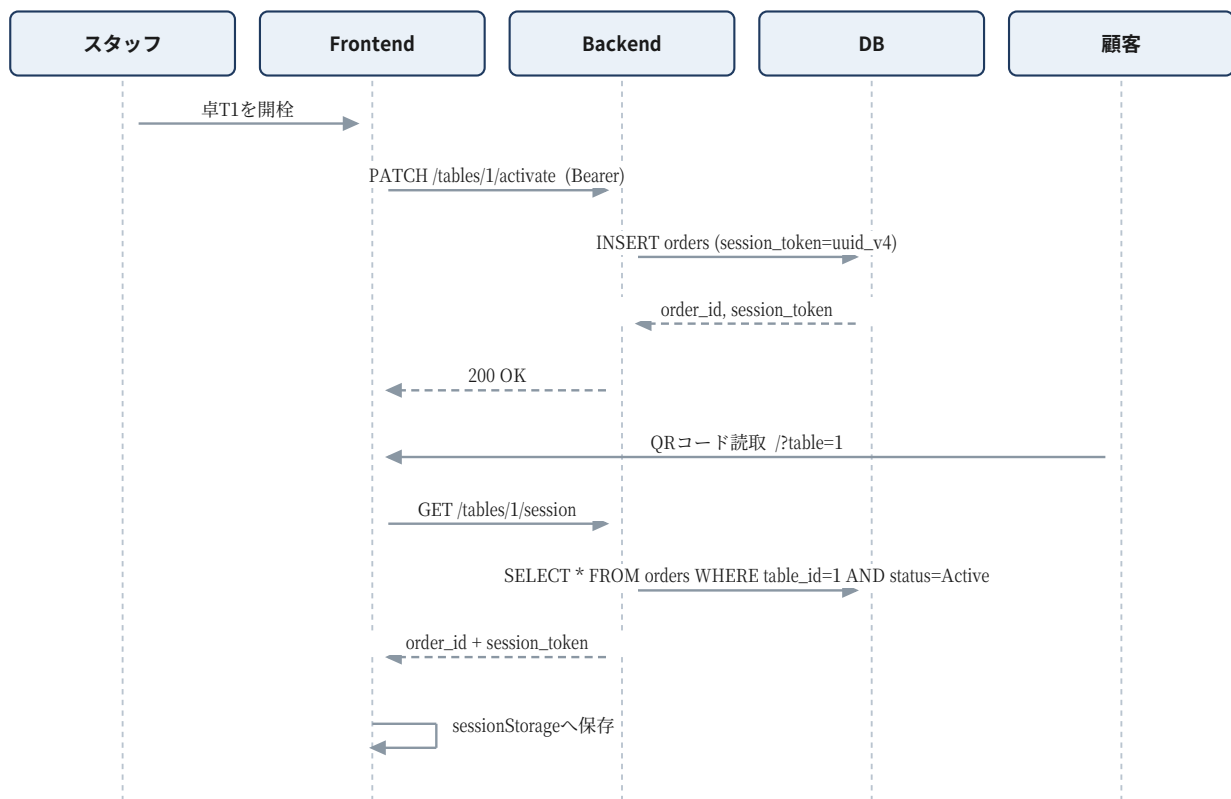


図2 開栓～顧客セッション取得シーケンス

- 卓のQRコードには tables.id (内部PK。以降 table_id) を埋め込む(/?table={table_id})。
- 未開栓(orders.status が Active でない)卓へのセッション取得アクセスは403 (TABLE_NOT_ACTIVE) を返す。
- 開栓時に session_token (UUID v4)
を新規発行し、以後この値がその注文セッションの正当性を証明する秘密情報となる。

2.4 顧客系APIのセッション検証(必須)

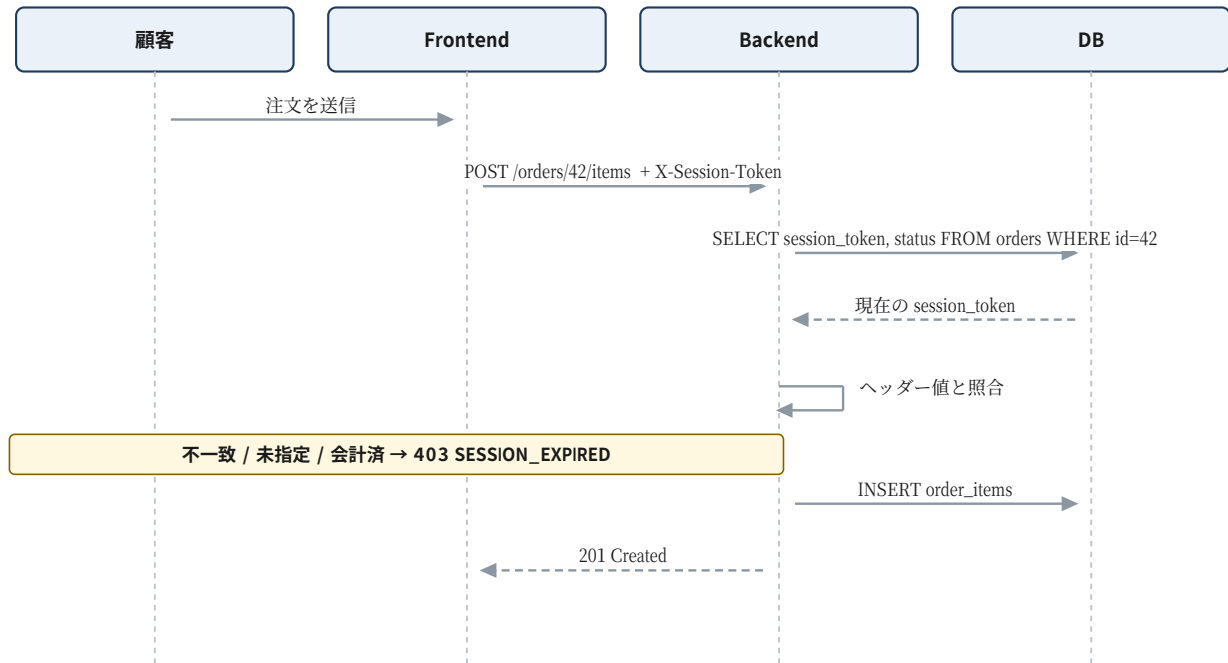


図3 セッション検証シーケンス(顧客系API共通)

セキュリティ上の要点

table_id / order_id は連番であり推測可能であるため、これらだけを鍵にすると他卓へのなりすましが成立する。そのため顧客系の全ての書込・参照APIで X-Session-Token を必須とし、Backendが対象 order_id の現在値と一致するかを毎回検証する。

session_token は開栓のたびにUUID

v4で再発行されるため、過去に漏洩したトークンは次の開栓以降は無効となる。会計クリア後も無効化される。

3. データアクセス制御(Supabase RLS)

全テーブルにRLSを有効化し、既定を「全ロール拒否(deny all)」とする。参照(SELECT)・更新(INSERT/UPDATE/DELETE)のいずれもBackend(Service Role Key)からのみ許可し、Anon Key・Authenticated Keyには一切のポリシーを付与しない。FrontendはSupabaseクライアントを持たないため、Anon Keyがブラウザに露出することはない。

テーブル	Anon Key	Service Role Key
products / tables	不可	SELECT / INSERT / UPDATE
orders / order_items	不可	SELECT / INSERT / UPDATE
staff	不可	SELECT / INSERT / UPDATE(パスワードハッシュを含むため特に厳格に管理)

4. リアルタイム性の実現方式

Supabase Realtimeの直接購読は3章の方針により採用しない。V1ではSWRによるポーリングで代替する。店舗規模(7卓)を踏まえると、数秒程度の反映遅延は業務上許容範囲と判断する。

画面	取得API	間隔	備考
STF-001 卓ダッシュボード	GET /api/v1/tables	4秒	ウィンドウフォーカス時にも再取得
STF-002 未提供リスト	GET /api/v1/staff/pending_items	4秒	同上
CST-003 注文履歴	GET /api/v1/orders/{id}/history	8秒	顧客端末の通信量に配慮し長め

将来、即時性が業務上必須になった場合は、Backend(Service Role Key)がSupabase Realtimeを購読し、認証済みWebSocket/SSEでスタッフ画面へ中継する方式への拡張を検討する(V1スコープ外)。

5. レート制限

対象API	制限	超過時
GET /api/v1/tables/{table_id}/session	同一IPから1分間に10回まで	429 (RATE_LIMITED)
POST /api/v1/staff/login	同一IPから1分間に5回まで	429 (RATE_LIMITED)

実装はslowapi (FastAPI向けのレート制限ライブラリ) を利用し、インメモリで保持する。単一インスタンス運用を前提とするため、V1では外部ストア(Redis等)は導入しない。

6. 幂等性・排他制御

- 開栓(PATCH /tables/{table_id}/activate)の二重実行を防ぐため、orders テーブルに部分UNIQUEインデックス UNIQUE (table_id) WHERE status = 'Active' を設定する。
- 既にActiveな卓に対して開栓が行われた場合、DB制約違反を捕捉して409 (TABLE_ALREADY_ACTIVE) を返す。
- アプリケーション側の事前チェックのみに頼らず、DB制約を最終防衛線とすることで、同時タップ等の競合状態でも整合性を保証する。

7. バッチ処理(daily_clear)

項目	内容
実行トリガー	Vercel Cron(毎日 AM 5:00 を想定。実際の営業時間に合わせて調整)
認証	リクエストヘッダー X-Cron-Secret を環境変数 CRON_SECRET と照合。不一致は401。
対象条件	orders.status = 'Active' の全レコード
処理内容	status を 'Deactivated' に更新し、is_calling を false にリセットする。checkout_staff_id は NULL のまま保持し、「スタッフによる正規の会計クリアではなかった」ことを記録する。
運用	翌営業日、checkout_staff_id が NULL の伝票が残っていないかをスタッフが確認する運用とする(システム上の通知機能はV1スコープ外)。

8. 共通エラーレスポンスフォーマット

APIがエラーを返す際、フロントエンドで一貫したエラーハンドリングを行えるよう、以下のJSONフォーマットで統一する。

```
{
  "error": {
    "code": "SESSION_EXPIRED",
    "message": "セッションが無効です。QRコードを再読み込みしてください。"
  }
}
```

8.1 エラーコード一覧

HTTP	code	発生条件	FEでの挙動
400	VALIDATION_ERROR	リクエストボディの形式・値が不正	入力内容の確認を促す
401	UNAUTHORIZED	スタッフAPIでBearerトークンが未指定・無効・期限切れ	ログイン画面へ遷移
403	TABLE_NOT_ACTIVE	未開栓の卓へのセッション取得アクセス	利用不可の案内を表示
403	SESSION_EXPIRED	X-Session-Tokenが不一致・未指定、または会計済セッション	sessionStorageを破棄しQR再読取を案内
404	NOT_FOUND	指定IDのリソースが存在しない	一覧を再取得
409	TABLE_ALREADY_ACTIVE	既にActiveな卓への重複開栓	「既に開栓済み」を表示し再取得
409	INVALID_STATUS_TRANSITION	許可されていないステータス遷移	一覧を再取得
429	RATE_LIMITED	レート制限超過	時間をおいて再試行を案内
500	INTERNAL_ERROR	予期しないサーバーエラー	汎用エラー表示

9. 変更履歴

版	主な変更内容
V3(ドラフト)	初版。Frontend直接のSupabase Realtime購読を前提とした構成。
V4(レビュー反映)	X-Session-Token必須検証を追加。FrontendのSupabase直接アクセスを廃止しポーリングへ変更。RLSを既定拒否に統一。レート制限・排他制御・daily_clear・JWT有効期限を明記。
V1.0 (FIX)	構成図・シーケンス図を追加。認証方式を一覧化し、エラーコードにFEの挙動を併記。レート制限とポーリングの実装方針を具体化。